Charles Pereira

Information Security Analyst

✉ chores265@hotmail.com
🔗 linkedin.com/in/charles-cyber-security/

Access Control Architecture and Governance (IAM)

Case Study • Cryptography and Security in Telecommuting Environments

1. Vulnerability Analysis and Business Context

With the transition to the telecommuting (home office) model, the organizational attack surface expands substantially. The main challenge of this project was to mitigate the risks of sensitive data exposure and unauthorized access outside the corporate network perimeter, ensuring full compliance with GDPR (and LGPD) guidelines and security standards guided by CERT.br.

It was necessary to formulate and execute an Information Security Policy (ISP) focused on strong authentication, prevention against social engineering, and mitigation of brute-force attacks against employee credentials.

2. Implemented Security Controls

Acting in the design and logical configuration of the access architecture, the following strategies were applied:

- **Multi-Factor Authentication (MFA):** Parameterization of login systems combining the factors "what you know" (high-complexity passwords) and "what you have/are", establishing a robust barrier against unauthorized access.
- **Cryptography and Digital Signature:** Architectural definition of the use of asymmetric keys (public and private) for the validation of transactions and documents, ensuring the principles of integrity, authenticity, non-repudiation, and legal validity of corporate operations.
- **Role-Based Access Control (RBAC):** Strict application of the *Principle of Least Privilege (PoLP)*. Employees were mapped individually according to their roles and segregated into Access Groups limited to departmental folders (Financial, Management, IT, etc.).

3. Technical Validation and Execution

Below are the evidences of configuration and access auditing in the simulated environment, demonstrating the assignment of permissions and the effective segregation of directory visibility (Segregation of Duties).

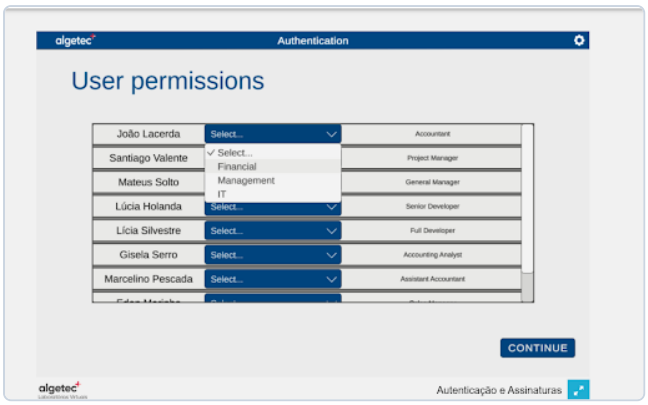


Fig 1. User mapping (e.g., João Lacerda) to restricted groups through RBAC policies, ensuring Least Privilege.



Fig 2. End-user Audit validation: isolated and restricted access exclusively to authorized folders.

4. Impact and Achieved Results

The implementation of these controls drastically reduced the risk of Lateral Movement in the network in case a credential is compromised, as the access radius is limited to the employee's role. Furthermore, the enforcement of the Acceptable Use Policy through the digital Statement of Responsibility ensures the organization's legal protection in Compliance audits and cyber incidents.